

网络攻防技术

攻击介绍：

攻击分类的标准及类别

标准：

- 互斥性（分类类别不应重叠）
- 完备性（覆盖所有可能的攻击）
- 非二义性（类别划分清晰）
- 可重复性（对一个样本多次分类结果一致）
- 可接受性（符合逻辑和直觉）
- 实用性（可用于深入研究和调查）

攻击者角度分类：

- 本地攻击（**Local Attack**）：指攻击者通过实际接触被攻击的主机实施的各种攻击方法
- 主动攻击（**Server-side Attack**）：指攻击者利用Web、FTP、Telnet等开放网络服务对目标实施的各种攻击。
- 被动攻击（**Client-side Attack**）：攻击者利用浏览器、邮件接收程序、文字处理程序等客户端应用程序漏洞或系统用户弱点，对目标实施的各种攻击。
- 中间人攻击（**Man-in-Middle Attack**）：指攻击者处于被攻击主机的某个网络应用的中间人位置，进行数据窃听、破坏或篡改等攻击。

攻击步骤与方法：

Information Gathering 信息收集

任务与目的：

尽可能多地收集目标的相关信息，为后续的“精确”攻击建立基础。

主要方法：

主动攻击

利用公开信息服务

主机扫描与端口扫描

操作系统探测与应用程序类型识别

Exploit 权限获取

任务与目的：

获取目标系统的读、写、执行等权限。

主要方法：

主动攻击

口令攻击

缓冲区溢出

脚本攻击.....

被动攻击

特洛伊木马

使用邮件、IM等发送恶意链接...

Control 安装后门

任务与目的：

在目标系统中安装后门程序，以更加方便、更加隐蔽的方式

对目标系统进行操控。

主要方法：

主机控制木马

Web服务控制木马

Lan Penetration 扩大影响

任务与目的：

以目标系统为“跳板”，对目标所属网络的其它主机进行攻击，最大程度地扩大攻击的效果。

主要方法：

可使用远程攻击主机的所有攻击方式

还可使用局域网内部攻击所特有的嗅探、假消息攻击等方法

Clearing 清除痕迹

任务与目的：

清除攻击的痕迹，以尽可能长久地对目标进行控制，并防止被识别、追踪。

主要方法：

Rootkit隐藏

系统安全日志清除

应用程序日志清除

物理攻击和社会工程学：

■ 物理攻击定义

◆ 通过各种技术手段绕过物理安全防护体系，从而进入受保护的设施场所或设备资源

内，获取或破坏信息系统物理媒体中受保护信息的攻击方式

防护手段：防盗、门禁安全、桌面安全

社会工程学攻击

- 利用人类的愚蠢，操纵他人执行预期的动作或泄漏机密信息的一门艺术与学问。

利用受害者心理弱点、本能反应、好奇心、信任、贪婪等心理陷阱进行诸如欺骗、伤害等危害手段。

防护：不用真名上网、不轻信别人、不让他人轻易接触设备、安全规范、涉密信息保护警觉

信息收集

公开信息收集的定义、内容、分类及必要性

定义：信息收集是指黑客为了更加有效地实施攻击而在攻击前或攻击过程中对目标的所有探测活动。

内容：

- 域名和**IP**地址
- 防火墙、入侵检测等安全防范措施
- 内部网络结构、域组织、用户电子邮件
- 操作系统类型
- 端口
- 系统构架
- 敏感文件或目录
- 应用程序类型

其他个人信息

必要性：

对敌方信息的掌握是关键

攻击者

先手优势

攻击目标信息收集

防御者

后发制人？

对攻击者实施信息收集，归因溯源

分类：

主动：通过直接访问、扫描网站，这种将流量主动量流经网站的行为

被动：利用第三方的服务对目标进行访问了解，比例：Google搜索

网络扫描：

分类：主机扫描、端口扫描、系统类型扫描

主机扫描：采用ping的方法，发送ICMP数据包的回显请求（用于差错的报告与控制）

通过高级IP技术实现：异常IP报头、IP中设置无效的字段值、错误的数据分片

端口扫描：分为TCP扫描和UDP扫描

基本扫描：TCP connect扫描

隐秘扫描：

①半连接扫描，扫描者向目标主机发送一个SYN，如果目标主机回复了一个SYN/ACK数据包，那么说明主机存活，如果收到一个RST/ACK数据包，那么主机没有存活。

②ACK, 设置flags位为ACK,不回复表示端口关闭或被过滤, 如果回复的数据包TTL小于等于64表示端口开放, 大于64端口关闭(windows)。

③FIN, FIN扫描和NULL扫描类似, 将标志位FIN置1, 如果端口开放, 则没有反应, 端口关闭, 目标主机会发送RST。

④Null, 设置flags位为空,不回复则表示端口开启, 回复并且回复的标志位为RS表示端口关闭

⑤Xmas, 设置所有标志位,不回复则表示端口开启, 回复所有标志位表示端口关闭

在udp实现的扫描中, 多是为了利用和icmp进行的组合进行, 这在icmp中以及提及了。还有一些特殊的就是udp回馈, 比如sql server, 对其1434端口发送'x02'或者'x03'就能够探测得到其连接端口。

系统类型扫描:

1.端口扫描结果分析: 由于现代操作系统往往提供一些自身特有的功能, 而这些功能又很可能打

开一些特定的端口

2.应用程序BANNER: 服务程序接收到客户端的正常连接后所给出的欢迎信息

TCP/IP协议栈指纹

3.不同的操作系统在实现TCP/IP协议栈时都或多或少地存在着差异。而这些差异, 我们就称之为TCP/IP协议栈指纹。

漏洞扫描:

直接测试: 是指利用漏洞特点发现系统漏洞的方法。

推断: 推断是指不利用系统漏洞而判断漏洞是否存在的方法。它并不直接渗透漏洞, 只是间接地寻找漏洞存在的证据。程序行为分析等

带凭证的测试: 提供一些基本的口令和API

网络拓扑探测：

拓扑探测：Traceroute技术：用来发现实际的路由路径或SNMP协议

网络设备识别：搜索引擎Shodan或设备指纹

网络实体IP地理定位：信息查询或时延

口令攻击

身份认证(Identification and Authentication)

用户向计算机系统以一种安全的方式提交自己的身份证明，然后由系统确认用户的身份是否属实，最终拒绝用户或者赋予用户一定的权限。

针对口令强度的攻击

- 字典攻击

- 强力攻击

- 组合攻击

- 撞库攻击

- 彩虹表攻击

针对口令存储的攻击

获取自动保存的口令

直接读取Windows内存的口令

破解SAM

Linux存储：shadow或password文件,算法+盐+密钥

Windows: SAM文件中，进行了保护

针对口令传输的攻击

嗅探

键盘记录

网络钓鱼

重放攻击

口令的防范：

选择安全密码

防止口令猜测攻击

设置安全策略

软件漏洞

漏洞的定义：指信息系统硬件、软件、操作系统、网络协议、数据库等在设计上、实现上出现的可以被攻击者利用的错误、缺陷和疏漏。

典型漏洞类型：

栈溢出、堆溢出、格式化串、整型溢出、释放再使用

堆栈内存中的分布：代码段、数据段、堆栈段

内存由高到低：参数及环境变量--栈--堆--未初始化全局或静态变量--初始化全局或静态变量--程序指令和只读数据。

栈中由高到低：实参--返回地址--之前EBP--局部变量

随着函数调用层数的增加，函数栈帧是一小块地向内存低地址方向延伸的。

漏洞利用内存变化：自己编

溢出流程：

注入恶意数据--溢出缓冲区--控制流重定向--执行有效载荷

关键技术：

- 溢出点定位
- 覆盖执行控制地址
- 覆盖异常处理结构
- 跳转地址的确定
- **Shellcode**定位和跳转

原理：本来是恢复ebp然后跳转到返回值继续执行，但覆盖后可能执行其他错误的有意义的操作。

Shellcode

定义：**ShellCode**就是一段能够完成一定功能(比如打开一个命令窗口)、可直接由计算机执行的机器代码，通常以十六进制的形式存在。

作用

恶作剧弹出对话框、dos窗口、添加管理员、打开远程端口、发起反向shell、上传病毒并运行、攻击性的删除等、破坏如磁盘

编写步骤：写出C程序--Windows函数调用原理--使用汇编生成Shellcode（机器码\x55）

通用shellcode编写：动态获得GetProcAddress地址--通过GetProcAddress获得其他函数地址--调用其他函数的地址

获取方法：通过TEB获取kernel32.dll地址--获取PE地址--获取引出表地址--获取三个数组地址--数组中获取GetProcAddress--获取其他函数序号--获取函数地址

环境变量

原理：由于用户可以设置环境变量，因此它们将成为Set-UID程序的攻击面的一部分。

fork和execve

envp和environ

shell变量和环境变量

Set-UID概念：允许用户以程序所有者的权限运行程序。允许用户以临时提升的权限运行程序

- 每个进程都有两个用户ID。

- **Real UID (RUID):**确定进程的真正所有者

- **Effective UID (EUID):**标识进程的权限

✓ 访问控制基于**EUID**

- 当执行正常程序时, $RUID = EUID$, 它们都等于运行程序的用户的ID

- 当执行**Set-UID**时, $RUID \neq EUID$. RUID还是用户 ID, 但是 **EUID** 是程序 owner 的 ID.

✓ 如果程序归**root**所有, 则程序以**root**权限运行。

攻击案例分析:

通过动态链接器攻击: 使用环境变量, 它将成为攻击面的一部分, 指向在程序中引用的外部库代码, 这意味着程序在编译期间未决定部分代码

LD_PRELOAD 包含一个共享库的列表, 链接器将首先搜索它;

对策: 这是由于动态连接器实现了一个对策。当**EUID**和**RUID**不同时, 它会忽略**LD_PRELOAD**和

LD_LIBRARY_PATH环境变量。

通过外部程序攻击: 应用程序本身可能不使用环境变量, 但被调用的外部程序可能会使用。如**system**调用**execve**, 其中参数涉及**PATH**

通过外部库攻击: 程序通常使用来自外部库的函数。如果这些函数使用环境变量, 则它们会

添加到攻击表面。

通过应用程序代码发动攻击: 程序可以直接使用环境变量。如果这些是特权程序, 它可能会导致不可信任的输入。

Set-UID方法和服务方法。

Web应用攻击

Web应用基础

结构：服务器--浏览器（客户端）--HTTP协议

XSS攻击

定义：**XSS**攻击是由于**Web**应用程序对用户输入过滤不足而产生的，使得攻击者输入的特定数据变成了**JavaScript**脚本或**HTML**代码

同源策略：它的含义是指，A网页设置的**Cookie**，B网页不能打开，除非这两个网页"同源"。所谓"同源"指的是"三个相同"。协议相同、域名相同、端口相同

危害：网络钓鱼、窃取信息、劫持（冒用）、网页挂马、恶意操作、Ddos、提权

代码漏洞分析及利用：

类型：

反射型：在url中，生成短网址伪装

存储型：留言、评论等数据库内容中

DOM：针对JS攻击，使用了DOM的不安全方法，完全前端，不需要联网

防范措施：**HttpOnly**（禁止脚本获取cookie）、安全编码、CSP

SQL注入攻击

定义：就是向网站提交精心构造的**SQL**查询语句，导致网站将关键数据信息返回

类型：

字符型SQL注入

数字型SQL注入

基于错误信息SQL注入

盲注入

注入步骤：注入点的发现（尝试注入）--数据库的类型（**user**等内置变量）--猜解表名--猜解字段名--猜解内容--进入管理页面上传木马（直接提交、改名、数据库备份、图片木马）

`oid=1 and 1=(select min(id) from admin where len (admin)>4)`

提权方法：

破解cif文件后，使用pcanywhere连接

利用servu来提升权限

破解sam密码

脚本提权

Nc反向连接

暴库定义：通过一些技术手段或者程序漏洞得到数据库的地址，并将数据非法下载到本地

防范措施：

特殊字符转义

输入验证和过滤

参数化方法：数据和代码分离

HTTP会话攻击及防御

预测会话ID：为防范预测会话ID号攻击，建议采用编程语言内置的会话管理机制

窃取会话ID：根据不同的窃取会话ID号方法，采取不同的防范措施，如基于XSS攻击实施的会话ID号窃取攻击，可以采用HttpOnly属性的方法来防范

控制会话ID

会话ID固定攻击：支持会话采纳（Session Adoption）的Web环境，存在会话ID号固定的风险比较高。因此，尽可能的采用非会话采纳的Web环境或对会话采纳方式进行防范。

会话保持：主要的防范措施就是不能让会话ID号长期有效，如采用强制销毁措施或用户登录后更改会话ID号等

CSRF跨站请求伪造攻击：POST、HTTP referer、验证码、Token

假消息攻击

包嗅探与欺骗的原理和攻击思路

TCP通信代码及流程

嗅探：数据包嗅探描述了在实时数据流经网络时捕获这些数据的过程

欺骗：当数据包中的某些关键信息被伪造时，我们称之为数据包欺骗。

socket代码

原始套接字代码

pcap API实现

scapy实现

嗅探+欺骗：

- 使用**PCAP API**捕获感兴趣的数据包
- 从**Captured Package**中复制一份
- 用新消息替换**UDP**数据字段，并交换源和目标字段
- 发出欺骗的答复

IP欺骗攻击及防范

TCP协议工作原理：传输层

■ **TCP**：在应用程序之间提供可靠且有序的通信通道。

■ **UDP**：具有较低开销的轻量级协议，可用于不需要可靠性或通信顺序的应用程序。

创建套接字--绑定端口--监听连接--接收请求--收发数据

三次握手

泛洪攻击原理+步骤

原理：为了填充存储半开放连接的队列，以便没有空间为任何新的半开放连接存储TCB，基本上服务器不能接受任何新的SYN数据包。

步骤：持续向服务器发送大量SYN数据包。这会通过插入TCB记录来消耗队列中的空间

后果：大量半连接但CPU利用率不高

对策：syn cookie

重置攻击原理+步骤：

原理：嗅探数据包信息（源ip、port、dstip、port、Seq），伪造发送RST包断开双方TCP连接

Telnet、SSH、视频流攻击

网络层加密、对连续的RST惩罚

TCP会话劫持攻击原理+步骤

原理：嗅探信息（换成序列号），伪造数据包，在已建立连接中注入数据（ack原理）

步骤：用户与服务器建立telnet连接--wireshark嗅探--检索信息--伪造发送--运行反向shell重定向

防御：

- 使攻击者难以伪造数据包

- 随机化源端口号
- 随机化初始序列号
- 对本地攻击无效
- 加密有效载荷

DNS攻击

域名结构：域名称空间以层次树状结构组织。顶级域（**top-TLD**）--第二级域（特定实体**edu**等）

查询过程：用户--本地DNS服务器--DNS SERVER 因特网上

迭代查询

递归查询

DNS响应：

- 问题部分：向名称服务器描述问题
- 回答部分：回答问题的记录
- 权威部分：指向权威名称服务器的记录
- 附加部分：与查询相关的记录。

DNS攻击类型和原理：

Dos: DNSPod: 暴风影音

DNS欺骗

本地**DNS**缓存中毒攻击

目标：在看到来自本地**DNS**的查询后伪造**DNS**应答，

远程**DNS**缓存中毒攻击

需要猜测源端口号和事务ID

卡明斯基攻击：每次询问不同的问题，因此缓存答案并不重要，并且本地DNS服务器每次都会发送一个新的查询。在权威部分提供伪造答案，将查询定向至攻击者主机

恶意DNS服务器的回复伪造攻击

当用户访问网站（如attacker32.com）时，DNS查询最终将到达attacker32.com

域的权威名称服务器。除了在响应的应答部分提供IP地址外，DNS服务器还可以在

授权和其他部分提供信息。攻击者可以使用这些部分提供欺诈信息。

我们可以使用从反向DNS查找获得的主机名作为访问控制的基础吗？

- 如果数据包来自攻击者，则反向DNS查找将返回到攻击者的名称服务器。
- 攻击者可以使用他们想要的任何主机名进行回复。

DNS重绑定攻击

在网页浏览过程中，用户在地址栏中输入包含域名的网址。浏览器通过DNS服务器将域名解析为IP地址，然后向对应的IP地址请求资源，最后展现给用户。而对于域名所有者，他可以设置域名所对应的IP地址。当用户第一次访问，解析域名获取一个IP地址；然后，域名持有者修改对应的IP地址；用户再次请求该域名，就会获取一个新的IP地址。对于浏览器来说，整个过程访问的都是同一域名，所以认为是安全的。（浏览器同源策略）这就是DNS Rebinding攻击。

防范：DNS固定

防范措施

DNSSEC是DNS的一组扩展，旨在对DNS数据提供身份验证和完整性检查。

传输层安全（TLS/SSL）协议提供了针对缓存中毒攻击的解决方案。HTTPS在此基础上设计

熔断与幽灵攻击

科学网—科普幽灵(Spectre) 与熔断(Meltdown)以及自测方法 - 岳东晓的博文
(sciencenet.cn)

□ CPU缓存原理

电脑在运行程序时，CPU要读取一个数据时，首先从缓存中查找，如果找到就立即送给CPU处理，缓存与CPU之间的数据交换速度要比CPU和内存之间快得多，如果CPU没有在缓存中找到需要的数据，就要慢速度从内存中读取并送给CPU处理，同时把这个数据所在的数据块调入缓存中。

□ 侧通道攻击原理

目前，绝大多数计算机均在CPU和内存之间增加CPU缓存（Cache），采用这种体系结构可以显著地提高程序的平均执行性能。然而，如果CPU访问Cache中并不存在的数据时，则将会产生时间延迟，因此此时目标数据必须重新从内存加载到Cache中。测量这种时间延迟有可能让攻击者确定出Cache访问失败的发生和频率。这就是基于缓存的侧信道攻击的基本原理。

刷新CPU缓存--访问存储器S位置--重新加载：检查缓存中是哪一个

□ 熔断攻击思路

在用户级别时先判断试图访问的空间是否非法，如果非法，则拒绝执行。INTEL的熔断缺陷是，其处理器先进行猜想性访问，然后再去判断是否合法，如果不合法就消除影响。这个看似无辜的顺序颠倒虽然不影响最终计算结果，却产生了系统其他部分如缓存的变化，这种变化使攻击者能推导出本来被禁止读取的信息内容。

□ 幽灵攻击思路（无序执行）

训练CPU执行某分支--刷新处理器缓存--引用受害者--重新加载检查是哪一个